La Plateforme

Cadrage des livrables NIS2 : cas HydroRégie

Ce qui est attendu à chaque bloc, avec schémas d'appui et repères réglementaires

Sommaire

1. Cadre de la consultation
2. Bloc 1 — Qualification NIS2
3. Bloc 2 — Analyse d'écart et feuille de route
4. Bloc 3 — Architecture réseau segmentée IT/OT
5. Bloc 4 — Gestion de crise et notification
6. Grille d'évaluation

La Plateforme

1

Cadre de la consultation

Objectif

Cette note précise, bloc par bloc, la forme et le contenu attendus des livrables du cas pratique HydroRégie. Elle complète le kickoff : elle ne remplace pas la lecture de la directive, elle sert de fil conducteur pour structurer vos rendus.

01

Qualification

Note de qualification réglementaire : statut, secteur, obligations.

02

Analyse d'écart

Matrice de conformité article 21 et feuille de route priorisée.

03

Architecture IT/OT

Schéma réseau segmenté, argumenté techniquement.

04

Gestion de crise

Chronologie d'incident et notifications réglementaires rédigées.

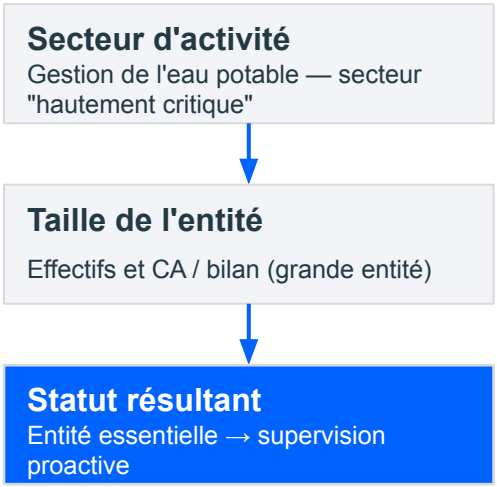
Format de dépôt : dossier GitHub structuré (1 sous-dossier par bloc). Chaque livrable doit être daté, nommé et directement lisible sans explication orale.

La Plateforme

BLOC 1

Qualification NIS2

Qualifier HydroRégie au regard de NIS2



REPÈRE RÉGLEMENTAIRE — Directive (UE) 2022/2555

Le statut d'entité essentielle ou importante dépend du croisement secteur d'activité (annexes I et II) et taille de l'entreprise (art. 2). Les entités essentielles sont soumises à une supervision ex ante ; les entités importantes à une supervision ex post.

Contenu attendu de la note de qualification

- Identification du secteur et du sous-secteur (annexe de la directive)
- Calcul de la taille (effectifs, CA/bilan) et statut résultant
- Liste des obligations applicables : gouvernance (art. 20), mesures (art. 21), notification (art. 23)
- Autorité compétente et démarche d'enregistrement à effectuer

La Plateforme

BLOC 2

Analyse d'écart et feuille de route

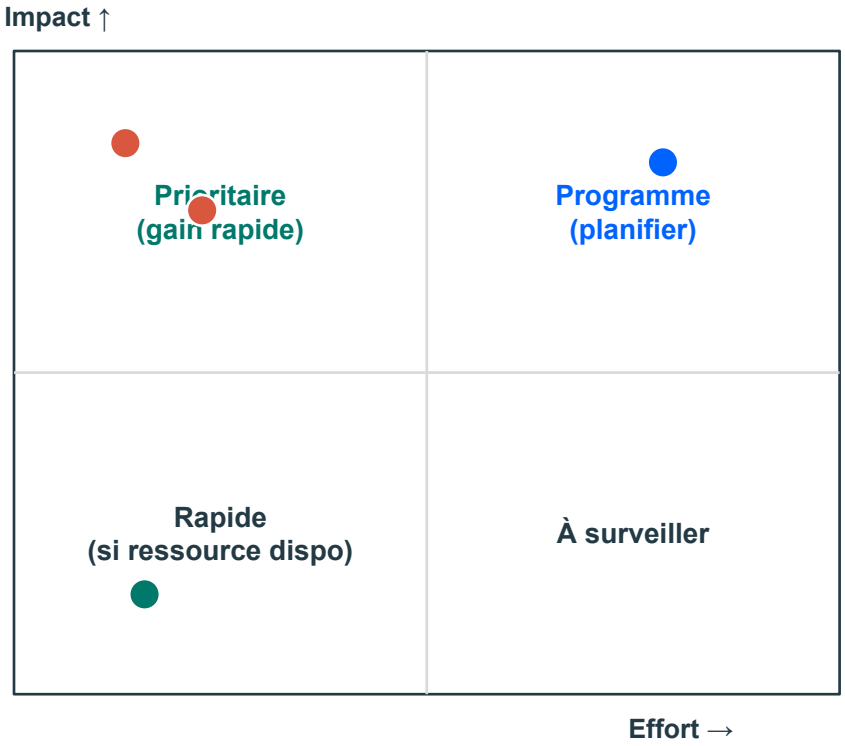
BLOC 2

Les 10 familles de mesures de l'article 21

L'analyse d'écart couvre chaque famille de mesures. Pour chacune : niveau de maturité actuel, écart, action et échéance.

1. Analyse de risques & politique de sécurité des SI
2. Gestion des incidents
3. Continuité d'activité & gestion de crise
4. Sécurité de la chaîne d'approvisionnement
5. Sécurité de l'acquisition, du développement et de la maintenance
6. Évaluation de l'efficacité des mesures
7. Hygiène informatique de base & formation
8. Cryptographie et chiffrement
9. Sécurité des ressources humaines & contrôle d'accès
10. Authentification forte & communications sécurisées

Matrice d'écart et priorisation



Contenu attendu de la feuille de route

- Couverture des 10 familles de mesures de l'article 21
- Écart constaté par mesure (conforme / partiel / absent)
- Priorisation impact / effort, avec justification
- Plan d'actions daté, responsabilisé (propriétaire, échéance)
- Indicateurs de suivi de la mise en œuvre

À noter : l'article 21 impose une approche « tous risques » et une obligation de moyens proportionnée, pas un standard technique unique à copier tel quel.

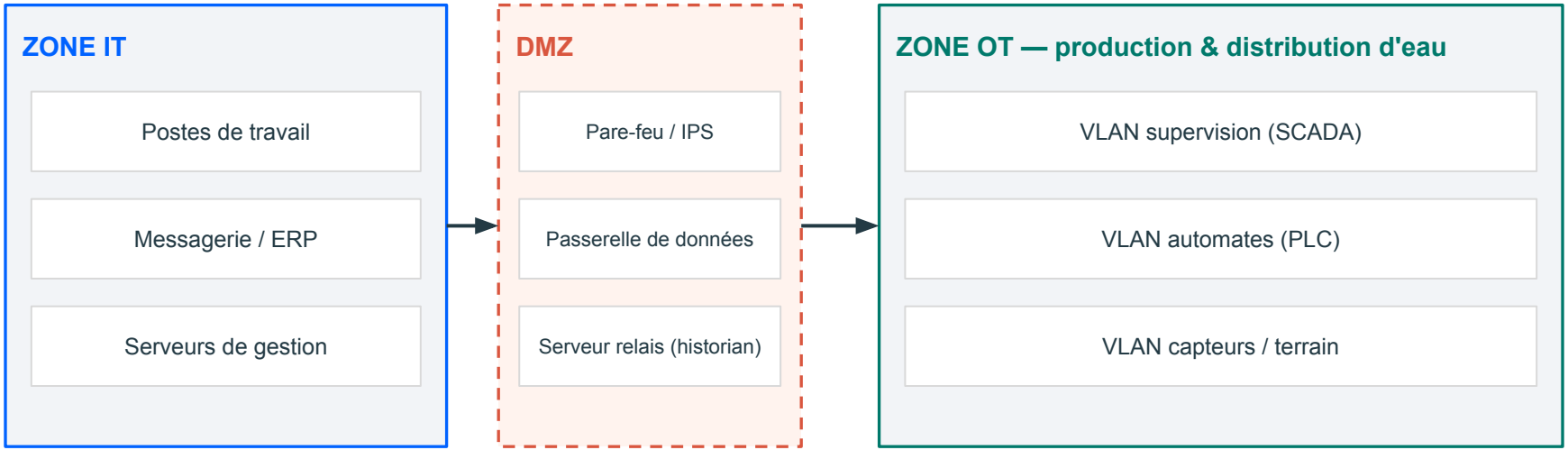
La Plateforme

BLOC 3

Architecture réseau segmentée IT/OT

BLOC 3

Segmenter le système d'information de gestion (IT) et le système industriel (OT)



Choix à justifier dans le livrable : règles de flux au pare-feu (sens unique IT→OT par défaut), usage du VPN pour la maintenance à distance, niveaux de criticité par zone, et continuité du service d'eau potable en cas de coupure du lien IT/OT.

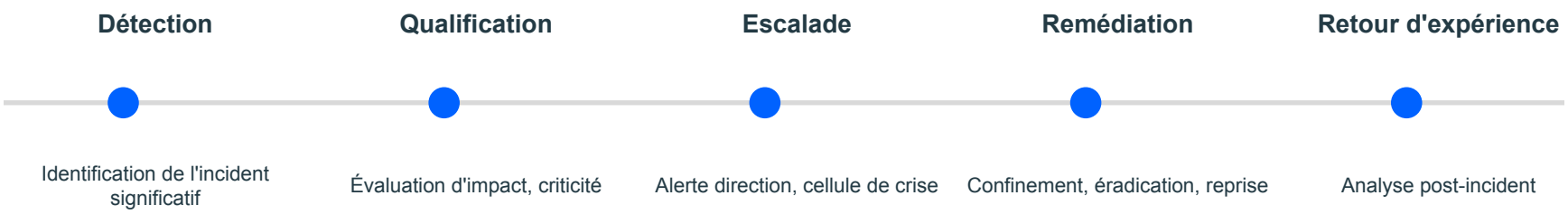
La Plateforme

BLOC 4

Gestion de crise et notification réglementaire

BLOC 4

Chronologie de crise et obligations de notification (article 23)



24 h

Alerte précoce

72 h

Notification d'incident

1 mois

Rapport final

Livrable attendu : chronologie horodatée de l'incident + les 3 documents de notification rédigés (alerte précoce, notification, rapport final), cohérents avec les délais ci-dessus et le contenu exigé par l'autorité compétente.

SYNTHÈSE

Grille d'évaluation

Livrable	Conformité réglementaire	Clarté & structuration	Argumentation technique
Note de qualification	Statut & obligations correctement identifiés	Lisible sans oral	Justification secteur/taille
Analyse d'écart & feuille de route	10 familles art. 21 couvertes	Priorisation explicite	Écarts reliés à des actions datées
Schéma d'architecture IT/OT	Segmentation réelle IT/OT	Légende & niveaux de criticité	Choix pare-feu/VLAN/VPN justifiés
Chronologie & notifications	Délais 24h/72h/1 mois respectés	Chronologie horodatée	Cohérence incident ↔ notifications

La Plateforme

Bon travail !

En cas de doute sur une exigence, référez-vous au texte de la directive (UE) 2022/2555, au site de l'ANSSI dédié à NIS2 et aux ressources de l'ENISA.